

1. RELAZIONE SULL' OSINT

Prima di avviare qualsiasi attività tecnica di Information Gathering, è fondamentale tracciare la linea di demarcazione tra un attacco informatico e un'attività di consulenza professionale o didattica autorizzata.

La presente attività è stata condotta esclusivamente in modalità **Passive Reconnaissance (Ricognizione Passiva)**. Questo significa che la raccolta di informazioni è avvenuta interrogando esclusivamente fonti aperte e database pubblici (OSINT - Open Source Intelligence), senza che sia stato inviato un singolo pacchetto dati diretto ai server proprietari del target o che siano state forzate misure di sicurezza.

Operare in modalità passiva garantisce il pieno rispetto del quadro normativo italiano, con particolare riferimento all'Art. 615-ter del Codice Penale, il quale punisce l'accesso abusivo a un sistema informatico o telematico protetto. Nel pieno rispetto delle linee guida etiche del MITRE ATT&CK Framework (Tattica TA0043 - Reconnaissance), non è stata violata alcuna OpSec e non è stata effettuata alcuna interazione diretta che potesse generare alert nei sistemi di difesa del target.

2. FASE 1: WHOIS & DNS RECONNAISSANCE

Come previsto dal workflow standard dell'Information Gathering, il primo passo ha riguardato la mappatura dell'infrastruttura di base e l'identificazione della proprietà del dominio.

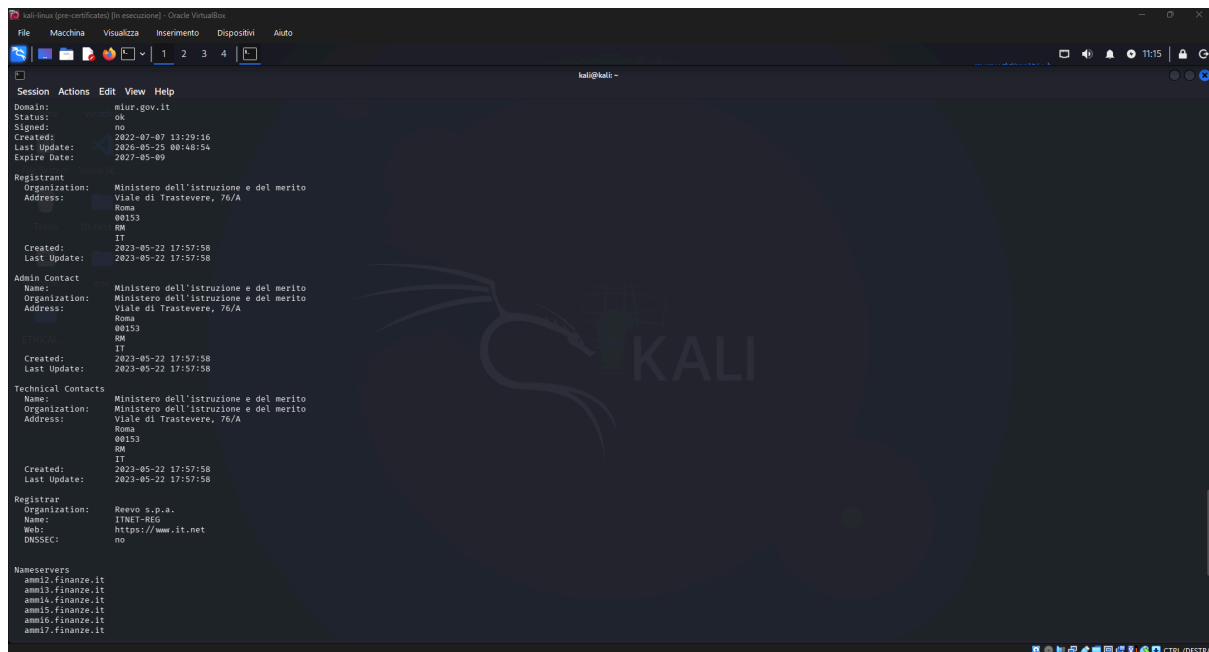
2.1 Analisi del Registro WHOIS

Tramite il terminale di Kali Linux è stata eseguita una query sul protocollo WHOIS per identificare l'assegnazione legale del dominio e le informazioni di contatto registrate.

```
Bash
whois miur.gov.it
```

Risultanze dell'analisi:

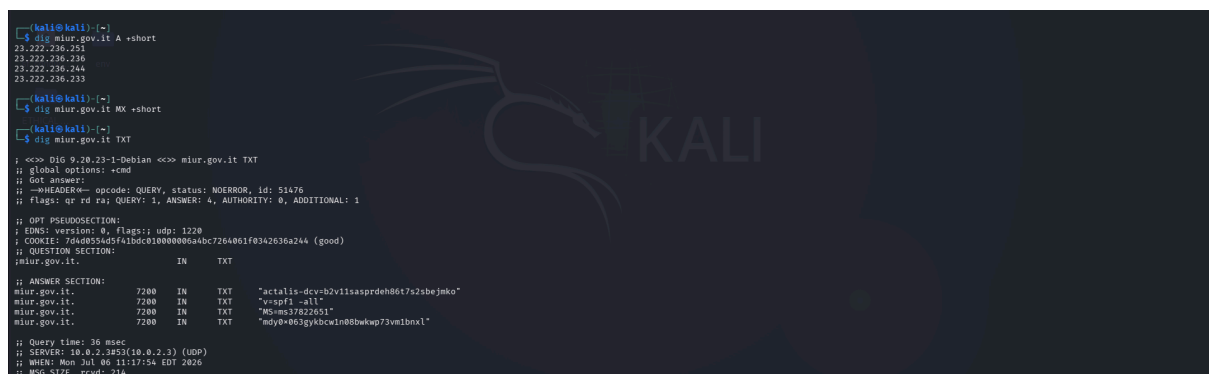
- **Registrant (Intestatario):** Ministero dell'Istruzione e del Merito, con sede a Roma in Viale di Trastevere 76/A. Il dato conferma l'autenticità istituzionale dell'asset analizzato.
- **Infrastruttura DNS:** I Name Server autoritativi rilevati ([ammi2.finanze.it](#), [ammi3.finanze.it](#)) indicano che la gestione dei record DNS è delegata ai sistemi informativi del Ministero delle Finanze, evidenziando una forte interconnessione infrastrutturale tra gli apparati statali.
- **Scadenza e Ciclo di Vita:** Il dominio presenta una scadenza a lungo termine, escludendo rischi immediati di *Domain Hijacking* legati a scadenze imminenti.



2.2 Analisi dei Record DNS tramite dig

Per mappare la superficie di rete pubblica e verificare i sistemi di validazione della posta, sono state effettuate query DNS mirate sfruttando il tool **dig**:

1. **Record A (Indirizzo IPv4):** Identifica l'IP pubblico associato al portale principale per scopi di hosting e geolocalizzazione.
2. **Record TXT (Security Policy):** Fondamentale per verificare la presenza di record di sicurezza e policy anti-spoofing (come SPF - Sender Policy Framework) per mappare come l'organizzazione protegge i propri canali email.



3. FASE 2: GOOGLE DORKING AVANZATO

La seconda fase ha previsto l'applicazione del **Google Dorking** (o Google Hacking), sfruttando gli operatori booleani e logici avanzati del motore di ricerca per identificare l'esposizione involontaria di file indicizzati o directory sensibili.

Sono state applicate rigorosamente le regole sintattiche che impongono l'assenza di spazi dopo i due punti dell'operatore e l'uso delle virgolette per le ricerche esatte.

Dork 1: Ricerca Documenti Riservati (PDF)

Plaintext

site:miur.gov.it filetype:pdf ("riservato" | "confidenziale" | "uso interno")

- **Obiettivo:** Individuare documenti in formato PDF che contengono marcatori di riservatezza e che sono stati indicizzati pubblicamente per un potenziale errore di configurazione dei crawler o del file **robots.txt**.

Dork 2: Esposizione Fogli di Calcolo (Excel)

Plaintext

site:miur.gov.it filetype:xls OR filetype:xlsx "personale"

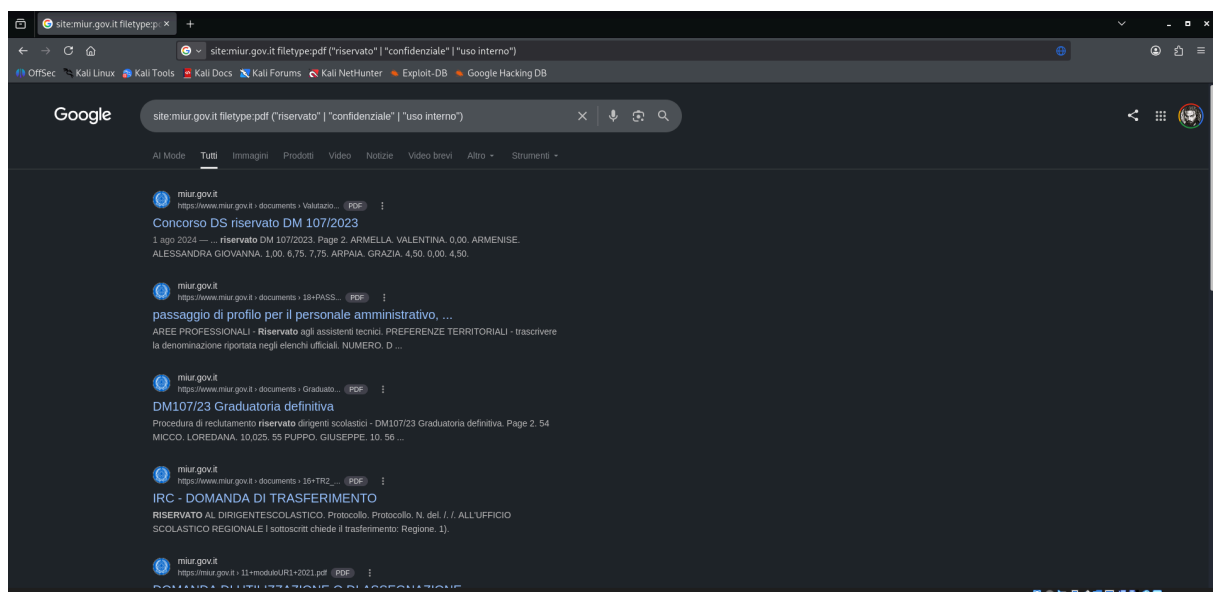
- **Obiettivo:** Individuare fogli di calcolo che potrebbero esporre elenchi di dipendenti, dati interni o informazioni utili alla profilazione degli asset umani, riducendo l'esposizione a vettori di Social Engineering.

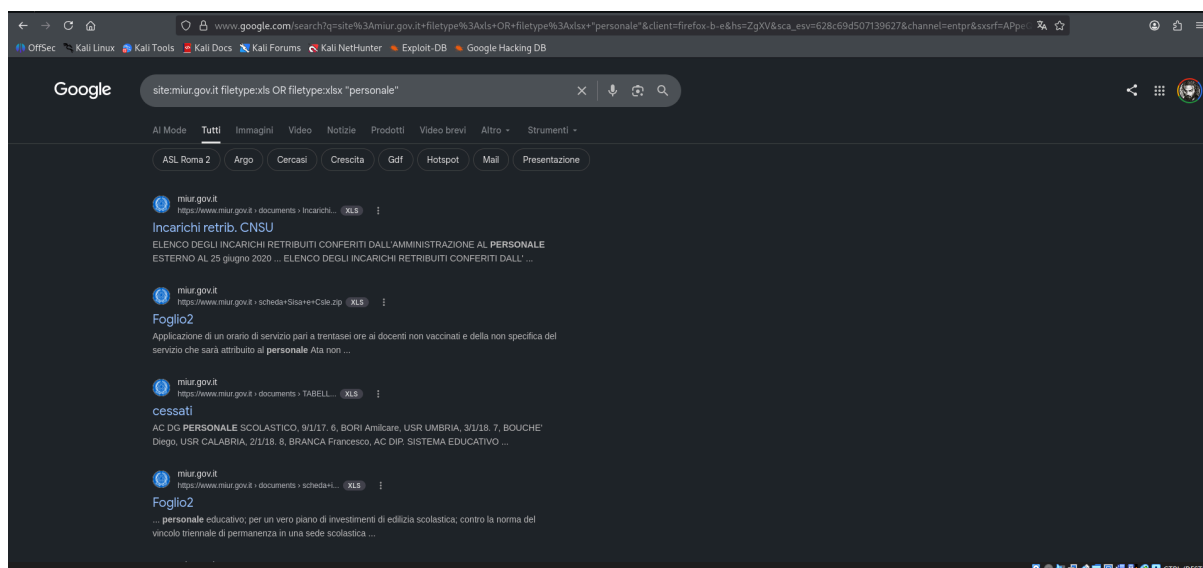
Dork 3: Controllo Directory Listing

Plaintext

site:miur.gov.it intitle:"index of"

- **Obiettivo:** Verificare l'esposizione ad albero di intere directory del server Web, configurazione errata che permette a utenti esterni di sfogliare i file direttamente dal browser.



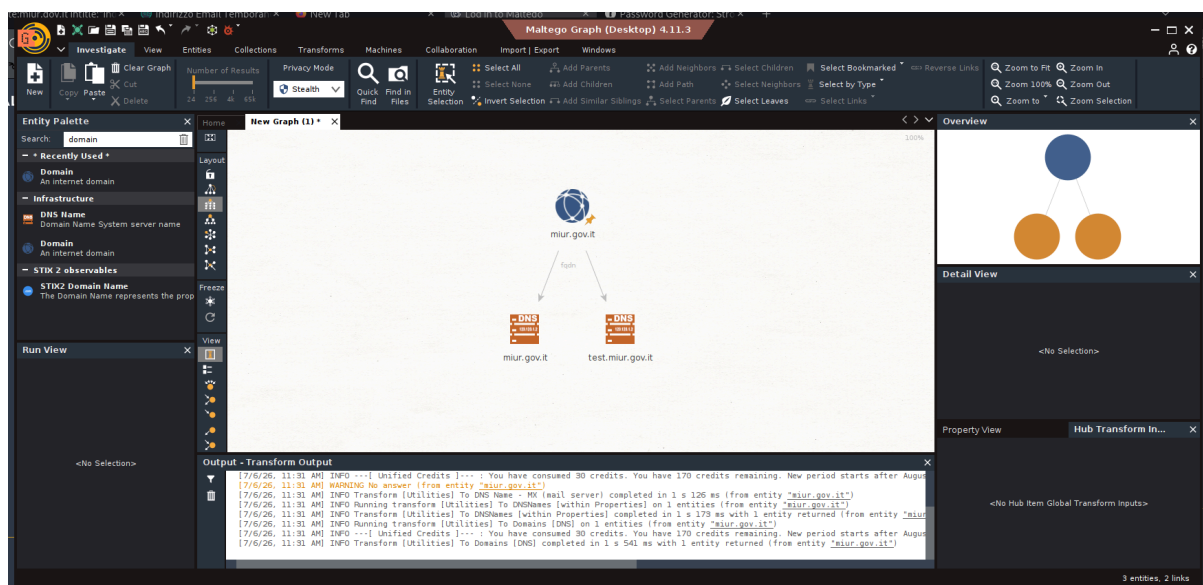


4. FASE 3: MAPPATURA VISIVA E LINK ANALYSIS CON MALTEGO

Come estensione avanzata dell'attività, i dati raccolti sono stati analizzati all'interno di **Maltego CE (Community Edition)** per eseguire una correlazione visiva e una Link Analysis strutturata dell'infrastruttura di rete.

1. È stata creata una nuova area di lavoro
2. È stata inserita l'entità iniziale di tipo **Domain** (trascinandola dalla palette dei componenti a sinistra) e configurata sul target **miur.gov.it**.
3. Sono state eseguite le **Transforms** DNS di Maltego

Questo processo ha consentito di mappare graficamente le relazioni logiche tra il dominio primario, la sfilza di sottodomini attivi (superficie di attacco web) e i relativi blocchi di indirizzamento IP, superando i limiti della classica visualizzazione testuale e strutturando i dati in modo chiaro ed efficace.



5. CONCLUSIONI E COMPLIANCE

L'attività ha dimostrato l'importanza fondamentale della fase di **Information Gathering** all'interno di un processo di sicurezza. La ricognizione passiva basata su tecniche OSINT permette di mappare accuratamente la superficie di attacco esposta a livello DNS e l'eventuale presenza di file sensibili indicizzati sui motori di ricerca aziendali, senza violare le normative vigenti e agendo in totale sicurezza.

Il monitoraggio periodico di queste fonti pubbliche rappresenta una best practice indispensabile per consentire alle organizzazioni di identificare tempestivamente leak di dati o misconfigurazioni infrastrutturali prima che possano essere sfruttate da attori malevoli nelle fasi successive della Cyber Kill Chain